

# PASTA threat model worksheet

*Sneaker marketplace mobile app. Process for Attack Simulation and Threat Analysis.*

A threat model of a mobile app that lets sneaker enthusiasts buy and sell shoes. The app handles account management and payments, and its technical scope includes an API, PKI, SHA-256, and SQL. The seven PASTA stages below trace from business objectives through to the controls that reduce the identified risks.

| Stage                                      | Response                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|--------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| I. Define business and security objectives | The app processes financial transactions and must support multiple secure payment options with reliable checkout, which brings payment-card data into scope. It is a marketplace connecting sellers and shoppers, so it requires account sign-up, authentication, and account management. Data privacy and lawful payment handling are stated priorities, so the app must meet industry regulations such as PCI DSS and general data-protection expectations.                                                              |
| II. Define the technical scope             | I would evaluate SQL first because it interfaces directly with the database holding user credentials, personal data, and payment information, which makes it the primary target for injection attacks. A single flaw in how queries handle input could expose the entire dataset. The API is the next priority, as it is the exchange point for all client and server data.                                                                                                                                                |
| III. Decompose application                 | The data flow diagram decomposes the product search process: the user submits a search query, the search process queries the database, and the database returns inventory listings. The trust boundary sits between untrusted user input and the database, so this single flow already shows where unsanitised input could reach SQL. Other processes such as login and checkout would be decomposed the same way.                                                                                                         |
| IV. Threat analysis                        | <b>Internal:</b> an insider or compromised internal account, such as an employee with broad database access, misusing or exfiltrating user and payment data.<br><b>External:</b> an outside attacker targeting the app's inputs and authentication, for example injecting malicious SQL through the search or login forms, or hijacking a user session.                                                                                                                                                                    |
| V. Vulnerability analysis                  | <b>SQL injection</b> caused by a lack of prepared statements or parameterized queries, allowing untrusted input to alter database queries.<br><b>Weak authentication</b> , such as weak login credential policies and no multi-factor authentication, enabling session hijacking and account takeover.                                                                                                                                                                                                                     |
| VI. Attack modeling                        | The attack tree sets the attacker goal as obtaining user data, with two branches. The first reaches it through SQL injection, enabled by a lack of prepared statements. The second reaches it through session hijacking, enabled by weak login credentials. Both branches map directly to the vulnerabilities listed in Stage V.                                                                                                                                                                                           |
| VII. Risk analysis and impact              | 1. Prepared statements and parameterized queries with input validation, to prevent SQL injection.<br>2. Multi-factor authentication, a strong password policy, and secure session management, to prevent session hijacking and account takeover.<br>3. Encryption of data in transit and at rest, using TLS through PKI, AES for stored data, and SHA-256 hashing for passwords.<br>4. Principle of least privilege and role-based access control on the database and API, to limit insider misuse and contain any breach. |

